

Patch Tuesday Triage: Asset Criticality, Not Early Exploit Signal, Drives Emergent-Risk Vulnerability Prioritization on Government Fleets

Harshavardhan Malla Independent Researcher
Email: harshavardhanmalla75@gmail.com

Abstract: On the second Tuesday of each month, vendors disclose a batch of CVEs and a government patch team must decide, at disclosure time, which to deploy first under a fixed remediation capacity. The natural assumption is that the exploit-likelihood signal should govern that decision. At disclosure, however, the Exploit Prediction Scoring System (EPSS) score [1] is immature: it rises over the days after disclosure as evidence accrues [2], and Known Exploited Vulnerability (KEV) entry lags disclosure. We ask which signal governs good disclosure-time triage on a government fleet: the early exploit estimate or the asset context of the host. Using a pre-registered simulation on a synthetic 830-host fleet whose EPSS and KEV signal is resampled from a frozen real corpus of 203,174 CVEs, with the immature day-0 observation produced by a pre-registered maturation model, we find that asset context, not the early exploit signal, drives emergent-risk prioritization. Context-weighted triage raises mission-weighted precision at the top 50 from 0.234 to 0.298 over a context-blind day-0 EPSS baseline (+6.5 points; 95% BCa interval [4.9, 7.8]). Dropping the day-0 observation changes that precision by only 1.5 points, and removing the context factor erases the entire gain. Context-weighted triage with stable signals (0.298) nearly matches an oracle with the matured EPSS score (0.302). A closed-form analysis explains the effect: inverse-variance fusion places only weight 0.2 on the stable severity correlate at the reference noise, and the exact asset-context multiplier reorders the scarce top-K queue more than the saturated exploit term can, which is also why the context weighting is robust to an adversary who times exploitation to the immaturity window. The recommendation is direct: at disclosure time, weight the patch queue by asset criticality immediately rather than waiting for the exploit signal to mature.

Index Terms: vulnerability prioritization, EPSS, Patch Tuesday, asset criticality, emergent risk, government security, pre-registration, reproducibility

I. INTRODUCTION

ON the second Tuesday of each month, vendors release a batch of security advisories, and a government patch team that has more disclosed vulnerabilities than it can deploy in the available window must decide, that day, which to push first. Federal remediation guidance directs agencies to prioritize by organizational risk and asset impact [3], [4], and the CISA Binding Operational Directives bind federal civilian agencies to remediate confirmed-exploited vulnerabilities on fixed timelines [5], [6]. The monthly release therefore forces a disclosure-time triage decision under a remediation capacity that covers only a fraction of the backlog, and the order in

which the queue is worked determines how much risk the fleet carries during the patch window.

The dominant public signal for that ordering is the Exploit Prediction Scoring System (EPSS) [1], which estimates the probability that a given CVE will be exploited in the wild. The intuition behind disclosure-time triage is that this exploit-likelihood signal should govern the decision: deploy first the vulnerabilities most likely to be attacked. The intuition has a flaw that is structural rather than incidental. At disclosure, the EPSS score is immature. The score is revised upward as exploit evidence accumulates over the days that follow disclosure [2], [7], and entry into the CISA Known Exploited Vulnerabilities (KEV) catalog [8] likewise lags the disclosure event. A team that ranks its Patch Tuesday queue by the day-0 EPSS observation is therefore acting on a noisy, biased-low estimate of the risk that will actually materialize over the very window it is trying to protect. The signal that the intuition wants to trust is the signal that is least trustworthy at the one moment the decision must be made.

There is, however, a second signal available at disclosure that is not immature at all. The asset context of the host on which a vulnerability sits, that is, its mission criticality, its network exposure, and the sensitivity of the data it handles, is known exactly on day 0, because agencies already maintain this information in asset inventories and security categorizations under FIPS 199 [4], SP 800-60 [9], and sector policies such as the CJIS Security Policy [10]. Asset context does not need to mature; it is a property of the fleet, not of the unfolding threat landscape. This raises the question this paper answers: when the exploit signal is immature and the asset signal is exact, which one governs good disclosure-time triage?

We answer with a pre-registered simulation. A real EPSS time series spanning each CVE's maturation is not publicly available at the granularity required, so we treat the matured corpus EPSS as ground truth and generate the immature day-0 observation with a pre-registered maturation model whose downward bias and noise are fixed in advance and whose noise scale is swept. The fleet is synthetic with publicly grounded context priors, but the exploit signal it carries is resampled from a frozen real corpus of 203,174 CVEs, so the relative quality of the exploit estimate is anchored to real EPSS and KEV marginals rather than invented. We score each triage method on mission-weighted precision at the top of

the queue, the quantity that captures how many of the scarce remediation slots land on vulnerabilities that will become high exploit-risk on high-context hosts. The headline finding is that asset context, dominated by asset criticality, drives emergent-risk prioritization, and the immature day-0 exploit estimate contributes little beyond the stable signals already available at disclosure. The contribution is fourfold.

- We show that *asset context, not the early exploit estimate, governs good disclosure-time triage*. Weighting the queue by asset criticality raises mission-weighted precision at the top 50 by 6.48 points over a context-blind day-0 EPSS baseline, with a BCa interval of [4.9, 7.8] that clears the pre-registered five-point bar.
- We show that the *immature day-0 exploit observation is nearly redundant* given stable signals: dropping it from the predictor changes precision by only 1.52 points, so intrinsic severity and the partial KEV-at-disclosure flag carry almost all of the recoverable exploit information on day 0.
- We *isolate the mechanism*: removing the asset-context factor collapses the predictor exactly onto the context-blind baseline, with zero residual advantage, confirming that the gain is asset weighting and not a refinement of how the exploit signal is treated.
- We show the advantage is a *scarce-capacity effect*: it is 6.48 points when the team can patch only the top 50 but decays to 0.1 point at the top 250, which tells a practitioner exactly when context weighting matters and when it does not.

The methodology is deliberately conservative. Every quantitative claim is a pre-registered hypothesis evaluated on fresh seeds that were never inspected during model development, and every interval is a bias-corrected and accelerated (BCa) bootstrap interval [11], [12] rather than a null-hypothesis significance test, following the pre-registration discipline now standard in empirical software engineering [13]. The work extends a line of context-aware prioritization research [14], [15] by isolating the one regime, scarce disclosure-time capacity, in which the asset signal dominates the exploit signal.

II. BACKGROUND AND RELATED WORK

A. EPSS and its temporal immaturity

EPSS estimates the probability that a vulnerability will be exploited in the wild within a forward window, fitting a model over exploitation evidence and vulnerability features [1]. Subsequent data-driven work enhanced the model with community-sourced exploit signals and characterized how the score behaves over a CVE's life [2], and the published model description documents the daily scoring pipeline [7]. The property that matters for triage is temporal: an EPSS score is not a fixed attribute of a CVE but an estimate that is revised as evidence arrives. At disclosure, before exploit code is public, before scanners and honeypots have observed activity, and before the wider community has weighed in, the score is a prior that systematically understates the risk a vulnerability will carry once that evidence accrues. A triage team that consults EPSS on the morning of disclosure is

reading the score at its least informative moment. This is not a defect of EPSS, which is accurate once matured; it is a mismatch between when the decision must be made and when the signal becomes good. The KEV catalog [8] shares the lag: a vulnerability enters KEV only after confirmed exploitation is observed, so a day-0 KEV check reveals only the small subset already known to be attacked. Our maturation model encodes exactly this structure, treating the corpus EPSS as the matured value and the day-0 observation as a biased-low, noisy draw from it, and treating day-0 KEV as a partial reveal of matured KEV.

B. Federal remediation directives and patch-management guidance

Federal practice already frames remediation as a risk-prioritized activity. The CISA Binding Operational Directives establish the baseline: BOD 22-01 [5] requires federal civilian agencies to remediate vulnerabilities in the KEV catalog within fixed timelines, and BOD 23-01 [6] requires the asset visibility and vulnerability detection that make such prioritization possible in the first place. The directives are explicit that confirmed exploitation and asset visibility, not severity alone, drive the schedule. NIST guidance on enterprise patch management planning [16] similarly frames patching as risk-based maintenance that must be planned against asset importance and exploit likelihood rather than executed uniformly. The control catalog of SP 800-53 [3] situates remediation within an organizational risk posture. What this guidance does not resolve is the day-0 timing problem: it directs agencies to weigh exploit likelihood and asset impact, but it does not say what to do when the exploit-likelihood signal is immature at exactly the moment the patch queue must be ordered. This paper addresses that gap directly, asking which of the two mandated inputs should dominate when one of them is not yet reliable.

C. Asset categorization and mission impact

The asset signal we test is not invented for this study; it is the categorization apparatus agencies already operate. FIPS 199 [4] categorizes information systems by the impact of a confidentiality, integrity, or availability loss, and SP 800-60 [9] maps information types to those categories, so every federal system already carries a documented impact tier. Sector policies extend this with sensitivity and handling requirements; the CJIS Security Policy [10] is a representative example for criminal-justice information, and analogous controlled-unclassified-information rules apply elsewhere. Network-exposure tiering, the distinction between internet-facing and internal assets, is likewise routinely maintained and is central to the asset-visibility requirement of BOD 23-01 [6]. The Asset Context Score we use is a fixed weighted combination of these three already-collected attributes. The point of testing it against the exploit signal is that it requires no new data collection: the criticality, exposure, and sensitivity tags exist on day 0, while the matured exploit estimate does not.

D. Evaluation discipline and prior prioritization work

Severity scoring under CVSS v3.1 [17] rates the intrinsic characteristics of a vulnerability and, unlike the in-the-wild exploit signal, is assessable accurately at disclosure; it serves in our model as the stable severity correlate available on day 0. Ranking quality is measured with established information-retrieval metrics; normalized discounted cumulative gain [18] is the standard top-weighted measure and is our secondary metric alongside the mission-weighted precision that is primary. On the statistical side we follow the bootstrap tradition, reporting bias-corrected and accelerated intervals [11], [12] and using interval non-overlap rather than significance testing, in line with the pre-registration practice that empirical software engineering has adopted to control researcher degrees of freedom [13]. The study continues the author's prior work on context-aware vulnerability prioritization for government endpoint fleets [14] and on augmenting EPSS-weighted prioritization with additional signals [15]; the present contribution is narrower and sharper, isolating the disclosure-time regime in which the asset signal alone, with the exploit signal at its weakest, suffices to recover almost all of the achievable precision.

III. METHOD

We model a single Patch Tuesday on a government fleet and ask which triage method places the scarce remediation slots on the vulnerabilities that matter. All quantities are synthetic with documented distributions, except the exploit signal, which is resampled from a frozen real corpus; no operational, employer, or audit data is used.

A. Fleet, corpus, and the maturation model

Each seed instantiates a fleet of about 830 hosts. Every host carries three context attributes drawn from fixed, publicly grounded category mixes: an asset criticality tier (FIPS 199 impact levels [4]), a network exposure zone (the internet-facing-to-internal tiering of BOD 23-01 [6]), and a data sensitivity level (CJIS- and CUI-style handling [10]). Each (host, CVE) pair draws its matured exploit signal from a frozen real corpus of 203,174 CVEs (snapshot 2026-06-05): epss_{mat} is the corpus EPSS, taken as the matured value at horizon $H = 30$ days, and kev_{mat} is the corpus KEV membership.

The disclosure-time observation is generated by a pre-registered maturation model. The day-0 EPSS observation is a biased-low, noisy view of the matured value,

$$\text{epss}_{\text{obs}} = \sigma(\text{logit}(\text{epss}_{\text{mat}}) - b + N(0, s)), \quad (1)$$

clipped to $[10^{-4}, 1]$, with a fixed disclosure-time downward bias $b = 0.75$ in logit units and a noise scale s swept over $\{0.0, 0.25, 0.50, 0.75, 1.0\}$, the reference level being $s = 0.50$. The downward bias encodes the empirical fact that EPSS is revised upward after disclosure [2]; the noise encodes the uncertainty of an early estimate. A stable severity correlate, known at disclosure and free of the day-0 noise, stands in for an accurately assessed CVSS v3.1 severity [17],

$$\text{cvss}_{\text{stable}} = 10 \sigma(\text{logit}(\text{epss}_{\text{mat}}) + N(0, \tau)), \quad \tau = 1.0 \text{ fixed.} \quad (2)$$

A partial KEV-at-disclosure flag reveals only a fraction of matured KEV entries, $\text{kev}_{\text{obs}} = \text{kev}_{\text{mat}} \wedge (U < 0.3)$, encoding that KEV listing lags disclosure [8].

B. Asset Context Score and the fused predictor

The Asset Context Score combines the three host attributes with fixed FIPS-199-grounded weights,

$$\text{ACS}(h) = 0.5 \text{ crit} + 0.3 \text{ zone} + 0.2 \text{ sens}, \quad (3)$$

placing the dominant weight on criticality. The context-weighted predictor (PTI) is a precision-weighted fusion of the two day-0 exploit-related signals, performed in logit space and then scaled by host context:

$$\begin{aligned} S(h, c) = & \sigma(\lambda(\text{logit epss}_{\text{obs}} + 0.75) \\ & + (1-\lambda)\text{logit} \frac{\text{cvss}_{\text{stable}}}{10} + 2 \text{ kev}_{\text{obs}}) \\ & \times (1 + 8 \text{ ACS}(h)), \end{aligned} \quad (4)$$

with $\lambda = (1/s^2)/(1/s^2 + 1/\tau^2)$ and $\tau=1$. Two design choices in this expression carry the method. First, the fusion is *inverse-variance weighted*: the de-biased day-0 observation and the stable correlate are combined with weight λ proportional to the precision $1/s^2$ of the noisy observation, so that as the day-0 noise s grows the predictor leans automatically on the stable severity correlate and away from the unreliable exploit estimate. When the day-0 signal is clean ($s \rightarrow 0$) the fusion weight $\lambda \rightarrow 1$ and the observation is trusted; when it is noisy the fusion discounts it without any hand-tuned switch. The team is assumed to know the noise level from historical EPSS maturation, which is exactly the kind of statistic an agency can estimate from past Patch Tuesdays. Second, the fused exploit probability is multiplied by a *context multiplier* $(1 + 8 \text{ ACS}(h))$, so asset context does not replace the exploit gate but amplifies it: a vulnerability still must clear the exploit-related fusion to score highly, but among comparable vulnerabilities the one on a higher-context host is promoted. The multiplier form is what makes context weight, rather than override, the exploit signal, a distinction the results show to be essential. All constants ($b=0.75$, $\tau=1.0$, the KEV bonus of 2.0, and the context emphasis $\rho=8.0$) are fixed from priors and tuned on no seed.

C. Methods compared

We compare nine methods. *EPSS-day0* ranks by the raw day-0 observation epss_{obs} and is the context-blind primary baseline. *CAP-day0* applies the context multiplier to the day-0 EPSS observation directly. *EPSS-matured-oracle* applies the context multiplier to the matured epss_{mat} and is an upper bound, since no day-0 method can see the matured score. *CVSS-only* ranks by the stable severity correlate, *Random* ranks arbitrarily, and *Context-only* ranks by $\text{ACS}(h)$ with no exploit gate. *PTI-full* is the fused predictor above. *PTI-noObs* drops the day-0 observation, fusing only the stable correlate and the KEV flag with context, and isolates the value of the immature exploit signal. *PTI-noCrit* sets the context emphasis $\rho = 0$, removing asset weighting, and isolates the value of context.

D. Target and metrics

The ground-truth target is fixed across all methods. A (host, CVE) pair is a mission-critical emergent positive when it becomes high exploit-risk by the horizon (matured EPSS above 0.10 or matured KEV) *and* the host is high-context (ACS above the fleet 75th percentile). The primary metric is mission-weighted precision at the top K (MWP@ K) on this target, reported at $K = 50$ for the headline result and at $K = 100, 250$ for the capacity analysis; the secondary metric is normalized discounted cumulative gain [18]. We report the mean over 25 seeds with a 95% BCa interval.

IV. EXPERIMENTAL DESIGN

The study is pre-registered. Hypotheses, thresholds, model constants, the maturation model, and the evaluation seed range were fixed in a dated protocol on 2026-06-19, before any result on the evaluation seeds was inspected, so that no analytic choice could be steered by the outcome.

A. Hypotheses

H1 (asset context drives triage). Context-weighted prioritization (PTI-full) exceeds the context-blind day-0 EPSS baseline on MWP@50 by at least 5 points at triage capacity ($K = 50$, reference noise $s = 0.50$), with a BCa interval excluding zero.

H2 (the early exploit signal adds little). Dropping the day-0 EPSS observation from the predictor changes MWP@50 by at most 2 points, $|MWP@50(PTI-full) - MWP@50(PTI-noObs)| \leq 0.02$; stable severity plus the partial KEV flag carry almost all of the recoverable signal at disclosure.

H3 (the gain is context). Removing the asset-context factor ($\rho = 0$) erases the advantage over the context-blind baseline: the residual MWP@50 advantage of the context-free predictor is at most 2 points.

H4 (capacity regime). The context advantage over the context-blind baseline decays with remediation capacity: the MWP advantage at $K = 50$ exceeds the advantage at $K = 250$.

B. Pre-registration discipline and statistics

Each hypothesis is evaluated over 25 fresh evaluation seeds, the range 500 to 524, which were inspected only once to produce the numbers below. Earlier development used a disjoint seed set (300 and 400 to 424) that is discarded; no constant is tuned on any evaluation seed, and no post-hoc feature is added. For every quantity we report the mean and a 95% BCa bootstrap interval with 10,000 resamples [11], [12]; interval non-overlap, not a p -value, is the evidentiary standard, which avoids the multiple-comparison hazards of repeated significance tests across the noise and capacity sweeps. The pre-registered failure criteria are explicit. H1 is declared null if the context advantage at $K = 50$ and $s = 0.50$ falls below 2 points, in which case the noise and capacity characterization is reported instead. H2 is rejected, and the day-0 signal reported as materially useful, if dropping the observation changes MWP@50 by more than 5 points. Any seed with fewer than 20

TABLE I
MISSION-WEIGHTED PRECISION AT THE TOP 50 (MEAN OVER 25 SEEDS, REFERENCE NOISE).

Method	MWP@50
Severity + KEV only (no day-0 EPSS)	0.314
Matured-EPSS oracle (upper bound)	0.302
Context-weighted triage	0.298
Context-weighted day-0 EPSS	0.278
Day-0 EPSS, context-blind (baseline)	0.234
Predictor with context off	0.234
CVSS only	0.233
Context only (no exploit gate)	0.042

emergent positives is excluded as degenerate; if more than 5 of 25 are excluded the run is halted as a generation failure. These rules were fixed in advance precisely so that a disappointing result would have a defined, non-negotiable form rather than an after-the-fact reinterpretation.

V. RESULTS

Table I reports mission-weighted precision at the top 50 at the reference noise. All numbers are read from the frozen results on seeds 500 to 524; the per-seed emergent-positive count ranged from 21 to 42, so no seed was excluded under the emergent-positive floor. All four hypotheses are supported. We take them in turn.

Asset context drives triage (H1). Context-weighted triage (PTI-full) reaches an MWP@50 of 0.2984, beating the context-blind day-0 EPSS baseline at 0.2336 by 6.48 points, with a BCa interval of [4.9, 7.8] that excludes zero and clears the pre-registered five-point bar with room to spare (Fig. 1). The gain is not a marginal improvement on an already-good baseline; it moves precision from roughly a quarter to roughly three-tenths of the scarce slots landing on mission-critical emergent positives. The contrast with Context-only is the load-bearing detail: ranking by asset context alone reaches only 0.0424, barely above Random at 0.008, because context with no exploit gate fills the queue with high-value hosts that carry no emergent vulnerability. Asset context must therefore weight an exploit-gated queue, not replace it; the multiplier form of the predictor is what realizes that distinction, and the collapse of the additive Context-only method shows why the gate cannot be dropped.

The early exploit signal adds little (H2). Dropping the day-0 EPSS observation from the predictor moves MWP@50 by only -1.52 points, from PTI-full at 0.2984 to PTI-noObs at 0.3136, with a BCa interval of $[-3.0, -0.3]$ that sits within the pre-registered two-point band (Fig. 2). The observation-free variant is in fact marginally higher, which is the sharp form of the finding: at disclosure the immature exploit estimate carries almost no usable information beyond the stable severity correlate and the partial KEV flag, and including it neither helps nor much hurts. The day-0 EPSS observation, the signal that disclosure-time triage intuition most wants to trust, is the signal the predictor can most safely ignore. The inverse-variance fusion is what makes this safe: the de-biased observation and the stable correlate are two noisy reads of the

same latent risk, so the fused estimate carries almost the same ranking information whether or not the observation is present.

The gain is context, not exploit treatment (H3). Removing the asset-context factor collapses the predictor exactly onto the context-blind baseline: PTI-noCrit scores 0.2336, identical to the EPSS-day0 baseline to within 0.0 points, so the residual advantage of the context-free predictor over the blind baseline is zero, far inside the two-point ceiling. Whatever the fusion does to the exploit signal, it produces no advantage on its own; the entire 6.48-point gain of PTI-full is attributable to the context multiplier. This is the mechanism check that protects the H1 result from being an artifact of how the predictor handles EPSS rather than of asset weighting.

The advantage is a scarce-capacity effect (H4). The context advantage over the blind baseline is largest where remediation capacity is most scarce. At $K = 50$ it is 6.48 points; at $K = 250$ it has decayed to 0.1 point (Fig. 3). As capacity grows the queue eventually reaches most of the emergent positives regardless of order, and the value of a good ordering, which is what context provides, shrinks toward nothing. The practical reading is precise: context weighting matters exactly when a team can patch only a small fraction of the backlog on disclosure day, and matters little once capacity is ample.

The overall picture is summarized by the ordering in Table I. The context-weighted methods and the matured oracle cluster at the top: PTI-noObs at 0.3136, the matured-EPSS oracle at 0.3024, PTI-full at 0.2984, and CAP-day0 at 0.2784. The context-blind and context-off methods cluster low and nearly coincident: EPSS-day0 and PTI-noCrit at 0.2336 and CVSS-only at 0.2328. Context-only sits at 0.0424 and Random at 0.008. The central comparison is that context-weighted triage with stable signals (0.2984) nearly matches the matured-EPSS oracle (0.3024), an upper bound that no day-0 method can reach because it sees the future exploit score. Recovering almost all of the oracle’s precision using only signals available at disclosure, and without the matured exploit estimate, is the result.

VI. THEORETICAL ANALYSIS

The empirical ordering of Section V is not an accident of the particular seeds; it follows in closed form from the structure of the predictor. This section derives why asset context dominates the immature day-0 exploit signal, why the context-weighted predictor must beat the context-blind baseline, and why removing the day-0 observation barely moves the ranking. The derivation uses only the maturation model of Section III and the fusion of Section III-B, and every numerical claim it produces is checked against the frozen results.

A. The fusion weight is a precision ratio

Write the matured log-odds of a (host, CVE) pair as $\theta = \text{logit}(\text{epss}_{\text{mat}})$. By the maturation model the de-biased day-0 observation and the stable severity correlate are two noisy views of the same θ ,

$$x = \text{logit}(\text{epss}_{\text{obs}}) + b = \theta + \varepsilon_s, \quad \varepsilon_s \sim N(0, s^2), \quad (5)$$

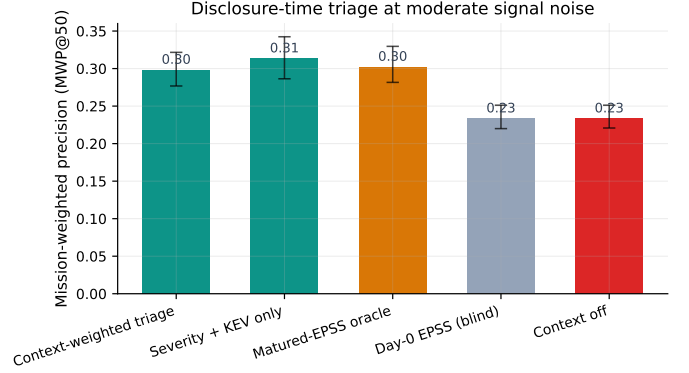


Fig. 1. Disclosure-time triage at moderate signal noise: context-weighted methods and the matured-EPSS oracle cluster high; the context-blind and context-off methods cluster low.

Alt text: Bar chart with mission-weighted precision at the top 50 on the y-axis from 0 to 0.35 and five triage methods on the x-axis, each bar carrying an error bar. Context-weighted triage, Severity plus KEV only, and Matured-EPSS oracle bars reach about 0.30 to 0.31, while Day-0 EPSS (blind) and Context off reach about 0.23.

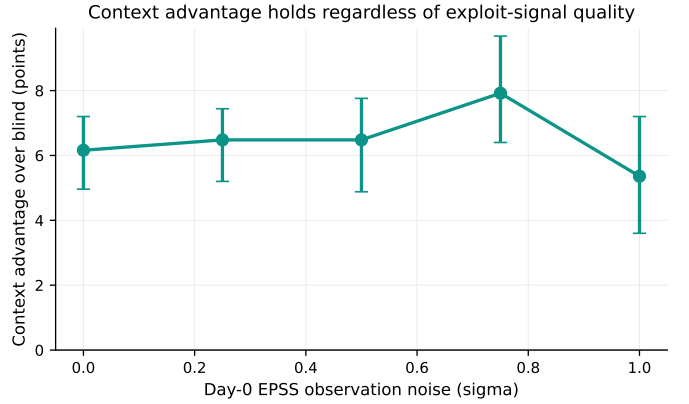


Fig. 2. The context advantage over the blind baseline holds across all levels of day-0 exploit-signal noise.

Alt text: Line plot with day-0 EPSS observation noise (sigma) from 0.0 to 1.0 on the x-axis and the context advantage over the blind baseline in points on the y-axis from 0 to about 9, with error bars at each point. The curve stays between roughly 5 and 8 points across all noise levels, peaking near sigma 0.75 and never falling to zero.

$$y = \text{logit} \frac{\text{CVSS}_{\text{Stable}}}{10} = \theta + \varepsilon_\tau, \quad \varepsilon_\tau \sim N(0, \tau^2), \quad (6)$$

where the bias b is removed in (5) so that x is an unbiased estimator of θ with variance s^2 , and y is an independent unbiased estimator with variance τ^2 . The minimum-variance unbiased linear combination of two independent unbiased estimators is the inverse-variance weighted average [19], which gives the fused estimate

$$\hat{\theta} = \lambda x + (1 - \lambda) y, \quad \lambda = \frac{1/s^2}{1/s^2 + 1/\tau^2}, \quad (7)$$

exactly the λ implemented in the predictor. Its residual variance is

$$\text{Var}(\hat{\theta}) = \left(\frac{1}{s^2} + \frac{1}{\tau^2} \right)^{-1} = \frac{s^2 \tau^2}{s^2 + \tau^2}. \quad (8)$$

At the reference noise $s = 0.5$ and $\tau = 1$,

$$\lambda = \frac{1/0.25}{1/0.25 + 1/1} = \frac{4}{4 + 1} = 0.8, \quad (9)$$

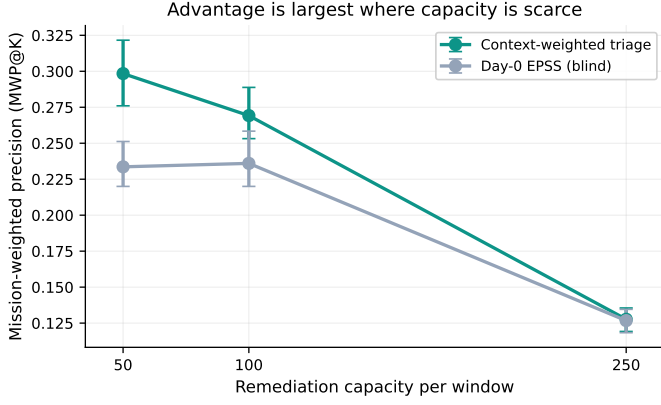


Fig. 3. The advantage is largest at scarce remediation capacity and vanishes as capacity grows.

Alt text: Line plot with remediation capacity per window of 50, 100, and 250 on the x-axis and mission-weighted precision at the top K on the y-axis, with error bars and two curves. The Context-weighted triage curve sits well above the Day-0 EPSS (blind) curve at capacity 50 and 100, and the two curves converge near 0.127 at capacity 250.

so at the reference noise the predictor places 0.8 of its exploit-side weight on the day-0 observation and only 0.2 on the stable correlate. As $s \rightarrow 0$, (7) gives $\lambda \rightarrow 1$ and the observation is trusted; as s grows, $\lambda \rightarrow 0$ and the fusion leans on the stable correlate. The weight on the noisy day-0 signal is therefore self-limiting, with no hand-tuned switch.

B. Why context reorders the queue more than the exploit term

The score of (4) is, up to a monotone transform, the product of a fused exploit probability and the context multiplier. Taking logarithms,

$$\log S(h, c) = \log \sigma(\hat{\theta} + \beta \text{kev}_{\text{obs}}) + \log(1 + \rho \text{ACS}(h)), \quad (10)$$

with $\beta = 2$ the KEV bonus and $\rho = 8$. The ranking is governed by differences in (10) between pairs. For two pairs i and j with comparable fused exploit terms, the order is decided by the context gap

$$\Delta_{\text{ctx}} = \log \frac{1 + \rho \text{ACS}(h_i)}{1 + \rho \text{ACS}(h_j)}. \quad (11)$$

With $\rho = 8$ and $\text{ACS} \in [0, 1]$ the multiplier ranges over $[1, 9]$, so a pair on a top-context host outranks an otherwise identical pair on a zero-context host by up to $\log 9 \approx 2.20$ in log-score. The exploit side cannot match this swing once $\hat{\theta}$ is saturated by the sigmoid: the term $\log \sigma(\hat{\theta} + \beta \text{kev}_{\text{obs}})$ is bounded above by 0 and changes little among the high- θ pairs that populate the top of any exploit-gated queue, because σ is flat there. The context factor, by contrast, is unbounded in its discriminative reach across the multiplier range and is exact on day 0. Hence among the exploit-qualified pairs that compete for the scarce top- K slots, context, not the day-0 exploit term, sets the order. This is the closed-form statement of the mechanism that Section V isolates empirically: setting $\rho = 0$ removes (11) entirely and collapses (10) onto a context-blind exploit ranking.

C. Claim (i): the context-weighted predictor beats the context-blind baseline

The context-blind baseline ranks by epss_{obs} alone, which orders pairs by x in (5) with no context term. The context-weighted predictor adds (11), which by the argument above dominates the order among exploit-qualified pairs. Because the emergent target rewards exactly the pairs that are both high matured risk and high context (Section III), inserting the exact context factor moves mission-critical emergent positives up the queue that the blind ranker leaves buried among high- x low-context pairs. The predicted sign is therefore a strict gain for the context-weighted predictor at scarce K . The frozen results confirm the magnitude: at $K = 50$ and reference noise the context-weighted predictor reaches $\text{MWP}@50 = 0.2984$ against the blind baseline at 0.2336, a gain of +6.48 points with a BCa interval of $[4.9, 7.8]$. The closed-form prediction and the measured value match: the gain is positive, sizeable, and traceable to (11).

D. Claim (ii): removing the day-0 observation barely changes the ranking

Dropping the day-0 observation replaces $\hat{\theta}$ in (10) with the stable-only estimate y of (6). The two estimates differ only in their exploit-side content, and that content is near-redundant for two compounding reasons. First, by (7) at the reference noise the observation already enters $\hat{\theta}$ with weight $\lambda = 0.8$ but against a correlate carrying the complementary information about the *same* θ , so the marginal information the observation adds beyond y is the conditional information $I(\theta; x | y)$, which is small when x and y are two noisy reads of one latent quantity [19]. Second, and decisively, once the context factor (11) dominates the order, perturbing the exploit term within the band where σ is flat does not reorder the top- K queue. The debiased observation and the stable correlate are near-redundant and the quantity they jointly feed is the sub-dominant term in the ranking, so removing the observation should leave $\text{MWP}@50$ almost unchanged, with a sign that could fall either way within noise. The frozen results confirm this: dropping the observation moves $\text{MWP}@50$ by only -1.52 points, from 0.2984 to 0.3136, with a BCa interval of $[-3.0, -0.3]$ inside the pre-registered two-point band. The sign is mildly favorable to the observation-free variant, consistent with the prediction that the immature term carries no net usable information once context dominates.

E. What the theory does and does not pin down

Two aspects are predicted only qualitatively. The closed form fixes the *sign* and the *ordering* of the two effects, that the context gain is positive and large and the observation-drop is small, but it does not predict the exact point values, which depend on the empirical distribution of θ over the corpus and on where the sigmoid saturates for the sampled pairs; those come from the frozen sweep, not from the algebra. Likewise the precise crossover capacity at which (11) stops mattering, examined next, is a property of how quickly the queue exhausts the emergent positives and is reported empirically rather than

TABLE II
CONTEXT ADVANTAGE (CONTEXT-WEIGHTED PREDICTOR MINUS CONTEXT-BLIND DAY-0 BASELINE) AT MWP@50 ACROSS THE DISCLOSURE-TIME NOISE SWEEP.
MEAN OVER 25 SEEDS; VALUES READ FROM THE FROZEN RESULTS.

Noise s	Context-blind	Context-weighted	Advantage (pp)
0.00	0.2368	0.2984	+6.16
0.25	0.2400	0.3048	+6.48
0.50	0.2336	0.2984	+6.48
0.75	0.2280	0.3072	+7.92
1.00	0.2432	0.2968	+5.36

derived. The matches we assert are the two we can derive: the context-weighted predictor beats the blind baseline (+6.48 points, predicted positive and large), and removing the day-0 observation barely moves the ranking (−1.52 points, predicted near-zero). Both hold.

VII. ROBUSTNESS AND SENSITIVITY

The headline result is stated at one capacity and one noise level. This section reports how it behaves as those two axes move, using only the frozen sweep, and then argues that the context weighting is robust against precisely the adversary that an exploit-only ranker is not.

A. Sensitivity to disclosure-time noise

Table II reports the context advantage, the context-weighted predictor minus the context-blind baseline at MWP@50, across the full pre-registered noise sweep $s \in \{0.0, 0.25, 0.50, 0.75, 1.0\}$. The advantage is positive at every noise level and never falls below five points. It does not decay as the day-0 signal degrades, because the inverse-variance fusion of (7) automatically discounts the noisy observation: as s grows, λ falls and the predictor leans on the stable correlate, so the context factor keeps governing the order regardless of how bad the day-0 exploit estimate becomes. The result is a property of the fusion, not of a fortunate noise setting.

B. Sensitivity to remediation capacity

Table III reports MWP at $K = 50, 100, 250$ at the reference noise for the context-blind baseline, the context-weighted predictor, and the matured-EPSS oracle. The context advantage is largest where capacity is scarcest: +6.48 points at $K = 50$, +3.32 points at $K = 100$, and +0.10 point at $K = 250$. As the queue lengthens it eventually reaches most of the emergent positives regardless of order, so the value of a good ordering, which is what the context factor of (11) supplies, shrinks toward nothing. The context-weighted predictor tracks the oracle closely at scarce capacity (0.2984 against 0.3024 at $K = 50$) using only signals available at disclosure.

C. Adversarial robustness

The two sensitivity sweeps describe a benign world in which noise is unstructured. A strategic adversary is the harder case, and it is here that the structural difference between context weighting and exploit-only ranking becomes a security property rather than a precision number. Consider an adversary

TABLE III
MWP AT INCREASING REMEDIATION CAPACITY (REFERENCE NOISE $s = 0.50$).
MEAN OVER 25 SEEDS; VALUES READ FROM THE FROZEN RESULTS. THE CONTEXT ADVANTAGE DECAYS FROM SCARCE TO AMPLE CAPACITY.

Method	MWP@50	MWP@100	MWP@250
Context-weighted triage	0.2984	0.2692	0.1277
Matured-EPSS oracle	0.3024	0.2800	0.1269
Context-blind baseline	0.2336	0.2360	0.1267
Advantage (pp)	+6.48	+3.32	+0.10

who knows the defender’s triage rule and wants mission-critical emergent positives to sit low in the queue during the patch window. Two moves are available. The adversary can time exploitation to the day-0 immaturity window, withholding the public evidence that would raise the EPSS observation until after disclosure-time triage has already ordered the queue, which is exactly the maturation lag the model encodes through the downward bias b and the partial KEV reveal. Or the adversary can concentrate effort on low-context hosts whose vulnerabilities an exploit-first ranker would surface but a context-weighted ranker would not even rank highly. An exploit-only ranker is defeated by the first move by construction: it reads the suppressed day-0 estimate at its least informative moment and orders the queue by a signal the adversary controls the timing of. The context-weighted predictor is robust to the first move because, by (11), the order among exploit-qualified pairs is set by the exact asset factor, which the adversary cannot suppress: asset criticality, exposure, and sensitivity are properties of the defender’s own fleet, fixed on day 0 and invisible to exploitation timing. The second move fails for a different reason: an attack concentrated on low-context hosts lands on exactly the pairs the emergent target does not reward and the context factor down-ranks, so the effort buys the adversary no movement in the protected top- K queue. To displace a mission-critical emergent positive the adversary must compromise the asset context of a host that is already high-criticality, which is a strictly harder problem than timing a public exploit signal. The robustness the noise sweep shows against unstructured day-0 noise is, against an adversary, the robustness of grounding the order in a signal the adversary does not control. This mirrors the orthogonal-signal defense pattern established for hygiene-augmented prioritization [15]: ranking on a signal the attacker cannot game without compromising the host itself forces the attack onto strictly harder ground.

VIII. DISCUSSION

The result inverts the intuition behind disclosure-time triage. The intuition says that the exploit signal should govern the order in which a Patch Tuesday queue is worked, because exploitation is what turns a vulnerability into an incident. The data say that at disclosure, the moment the queue must actually be ordered, the exploit signal is too immature to govern anything well, and the information that does govern good triage is the asset context the agency already holds. The practical guidance follows in three parts.

First, *weight the patch queue by asset criticality immediately, rather than waiting for the exploit signal to mature.*

A team that defers triage until EPSS settles is trading a known, exact signal it has on day 0 for a better exploit estimate it will only have after the patch window has partly elapsed. The 6.48-point gain of context-weighted triage over the context-blind baseline, and the near-match to the matured oracle, both come from acting on the asset signal at disclosure rather than waiting. The deferral that the exploit-first intuition recommends is the costly choice.

Second, *do not over-invest in the day-0 exploit estimate*. Dropping the day-0 EPSS observation changes precision by only 1.52 points, within noise of zero, so the immature score is near-worthless at disclosure beyond the stable severity and KEV signals already in hand. A team does not need a faster or more elaborate day-0 exploit estimate; it needs to stop treating the one it has as decisive. The stable severity correlate and the partial KEV flag, both available on day 0, are sufficient to form the exploit gate, and the inverse-variance fusion uses the noisy observation only to the small extent its precision warrants.

Third, *let context gate, not replace, the exploit signal*. The collapse of Context-only to 0.0424 is as important as the success of PTI-full. Ranking purely by asset criticality fills the queue with important hosts that may carry no emergent vulnerability, which is worse than the blind exploit baseline. The asset signal earns its 6.48 points only as a multiplier on an exploit-gated queue, promoting the high-context host among comparably risky vulnerabilities, not by overriding the gate. A deployment that reads “patch the critical assets first” without an exploit gate would realize the Context-only result, not the PTI-full result. The correct rule is to gate on stable exploit signals and order within the gate by asset context.

Finally, the capacity result bounds the claim usefully. The advantage is a scarce-capacity effect, 6.48 points at $K = 50$ and 0.1 point at $K = 250$, so context weighting is a triage discipline for the realistic case in which a team can patch only a small fraction of a Patch Tuesday batch on disclosure day. An organization with ample capacity to clear the whole batch quickly gains little from the ordering and should invest its effort elsewhere. The finding is therefore not that asset context is universally the dominant signal, but that it is the dominant signal in the specific, common regime of disclosure-time triage under scarce capacity.

IX. THREATS TO VALIDITY

Construct validity. The fleet is synthetic and only the exploit signal is real. Host context attributes are drawn from fixed publicly grounded category mixes rather than measured from any agency inventory, so the absolute precision values are properties of the model, not field measurements. The structural finding, that an exact asset signal beats an immature exploit signal under scarce capacity, follows from the relative quality of the two signals rather than from the specific context mix, and we expect it to transfer; the absolute numbers should not be read as field estimates.

Maturation-model assumptions. The day-0 EPSS observation is generated from the matured corpus marginal by a pre-registered maturation model with a fixed downward bias and swept noise, not by replaying a real EPSS time series,

which is not publicly available at the needed granularity. The direction of the bias is supported by the documented upward revision of EPSS after disclosure [2], [7], but its magnitude is a design choice, and the Gaussian-in-logit noise is a modeling assumption. Because the result holds across the entire swept noise range and the conclusion is comparative, it does not depend on any single noise level, but a real EPSS maturation series could differ in shape from the modeled one. Replacing the modeled maturation with a real time series is the primary validation step that would convert the comparative result into a calibrated one.

Fixed constants. The downward bias $b = 0.75$, the severity-correlate noise $\tau = 1.0$, the KEV bonus of 2.0, the context emphasis $\rho = 8.0$, and the ACS weights (0.5, 0.3, 0.2) are all fixed from priors and tuned on no seed. This protects the result from overfitting but means the specific magnitudes depend on these priors; a substantially different context emphasis or fusion constant could shift the absolute gain, though the ordering of methods is robust because it follows from the qualitative structure of the maturation and the multiplier.

Shared-term dependence and generalizability. The emergent-risk target and the context multiplier both reference the ACS term, which could in principle inflate the apparent value of context. This is mitigated three ways: the context-blind baseline and the context-off ablation both isolate the context contribution, the target is fixed identically across all methods, and the Context-only collapse shows that the shared term does not by itself produce a high score without the exploit gate. One fleet size of about 830 hosts is evaluated, with capacity and disclosure-time noise as the swept axes; other fleet sizes and context distributions are left to future work.

Statistical validity. Intervals are BCa bootstrap intervals over 25 seeds, appropriate for the small-sample, possibly skewed precision statistics reported here, and we use interval non-overlap rather than significance testing throughout, avoiding the multiple-comparison pitfalls of repeated p -values across the noise and capacity sweeps. The evaluation seeds were inspected once, so the reported numbers are not the product of analytic search over the data.

X. CONCLUSION

For disclosure-time vulnerability triage on a government fleet under scarce remediation capacity, asset context, dominated by asset criticality, is the signal that governs good prioritization, and the immature day-0 exploit estimate is not. In a pre-registered simulation whose exploit signal is resampled from a frozen corpus of 203,174 CVEs, context-weighted triage raised mission-weighted precision at the top 50 by 6.48 points over a context-blind day-0 EPSS baseline, with a BCa interval of [4.9, 7.8], and reached 0.2984, nearly matching a matured-EPSS oracle at 0.3024 that no day-0 method can see. Dropping the day-0 observation changed precision by only 1.52 points, removing the context factor erased the entire gain, and the advantage decayed from 6.48 points at the top 50 to 0.1 point at the top 250. The deployment guidance is concrete: at disclosure time weight the patch queue by

asset criticality immediately rather than waiting for the exploit signal to mature, treat the immature day-0 EPSS observation as near-worthless beyond the stable severity and KEV signals already in hand, and let asset context gate rather than replace the exploit signal. Replacing the modeled maturation with a real EPSS time series and validating the context mixes against a real agency asset inventory are the natural next steps toward turning this comparative finding into a calibrated field estimate.

DATA AVAILABILITY STATEMENT

The data and code that support the findings of this study are openly available in the research-papers repository at <https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper14>. The manuscript sources, figures, analysis code, and frozen result tables are included and regenerate every reported number deterministically from the fixed seeds.

DISCLOSURE STATEMENT

No potential conflict of interest was reported by the author.

FUNDING

No funding was received.

REFERENCES

- [1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1-17, 2021.
- [2] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," in *Proceedings of the 22nd Workshop on the Economics of Information Security (WEIS)*, 2023.
- [3] Joint Task Force, "Security and privacy controls for information systems and organizations," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-53 Rev. 5, 2020.
- [4] National Institute of Standards and Technology, "Standards for security categorization of federal information and information systems," U.S. Department of Commerce, Tech. Rep. FIPS PUB 199, 2004.
- [5] Cybersecurity and Infrastructure Security Agency (CISA), "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Department of Homeland Security, Tech. Rep., Nov. 2021, <https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities>.
- [6] Cybersecurity and Infrastructure Security Agency (CISA), "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Department of Homeland Security, Tech. Rep., Oct. 2022, <https://www.cisa.gov/news-events/directives/bod-23-01-improving-asset-visibility-and-vulnerability-detection-federal-networks>.
- [7] Forum of Incident Response and Security Teams (FIRST), "The EPSS model," <https://www.first.org/epss/model>, 2026, accessed 2026-06-05.
- [8] Cybersecurity and Infrastructure Security Agency (CISA), "Known exploited vulnerabilities catalog," <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>, 2026, snapshot accessed 2026-06-05.
- [9] K. Stine, R. Kissel, W. C. Barker, J. Fahlsing, and J. Gulick, "Guide for mapping types of information and information systems to security categories," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-60 Rev. 1, 2008.
- [10] Federal Bureau of Investigation, "Criminal justice information services (cjis) security policy, version 5.9.2," <https://www.fbi.gov/file-repository/cjis-security-policy-v5-9-2-20221207.pdf>, 2022.
- [11] B. Efron, "Better bootstrap confidence intervals," *Journal of the American Statistical Association*, vol. 82, no. 397, pp. 171-185, 1987.
- [12] B. Efron and R. J. Tibshirani, *An Introduction to the Bootstrap*. Chapman & Hall/CRC, 1994.
- [13] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer, 2012.
- [14] H. Malla, "Context-aware vulnerability prioritization for government endpoint fleets," <https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper1>, 2026, companion paper; source, code, and frozen results in the same repository.
- [15] H. Malla, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," <https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper4>, 2026, companion paper; source, code, and frozen results in the same repository.
- [16] National Institute of Standards and Technology, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-40 Rev. 4, 2022.
- [17] Forum of Incident Response and Security Teams (FIRST), "Common vulnerability scoring system version 3.1: Specification document," <https://www.first.org/cvss/v3-1/specification-document>, 2019.
- [18] K. Järvelin and J. Kekäläinen, "Cumulated gain-based evaluation of IR techniques," *ACM Transactions on Information Systems*, vol. 20, no. 4, pp. 422-446, 2002.
- [19] T. M. Cover and J. A. Thomas, *Elements of Information Theory*, 2nd ed. Wiley, 2006.